

Informe de Conclusión y Diagnóstico Post-Intervención: OmniBank

Resumen de Gestión de Riesgos, Métricas y Plan de Certificación APDP

Unidad de Negocio: OmniBank (Sector Financiero / Operador de Importancia Vital) **Consultor Líder:** Gonzalo Vega Batyi, Abogado / DPO **Marco de Referencia:** ISO 31000:2018 | ISO 27701 (SGPI) | Ley 21.663 **Fecha de Cierre:** Mayo 2026 **Próxima Revisión:** Noviembre 2026 (Auditoría Semestral OIV)

1. Diagnóstico de Cierre y Resumen Ejecutivo

Tras completar el ciclo de auditoría y tratamiento bajo la metodología **ISO 31000**, se ha logrado neutralizar el escenario de **Riesgo Crítico (Nivel 25)** detectado en la Fase 2. La intervención ha subsanado la vulneración del Principio de Finalidad (Art. 9 Ley 21.719) y ha blindado la Infraestructura Crítica de la Información (ICI) mediante la implementación de *Air Gapping* lógico, separando el Core Bancario de las operaciones de marketing del Holding.

1.1 Matriz Visual de Mitigación del Riesgo

(Escala de Evaluación: 1: Bajo/Controlado - 5: Extremo/Crítico)

Dimensión Evaluada	Riesgo Inicial (Fase 2)	Riesgo Residual (Post-Controles)	Impacto de Mejora
Licitud (Finalidad 21.719)	(5) ☒ ☒	(1)	Riesgo Mitigado
Reserva Bancaria (LGB)	(5) ☒ ☒	(1)	Riesgo Mitigado
Disponibilidad OIV (21.663)	(5) ☒ ☒	(2)	Riesgo Aceptable
Accountability (ISO 27701)	(4) ☒	(1)	Riesgo Mitigado
Integridad de Activos ICI	(5) ☒ ☒	(1)	Riesgo Mitigado

2. Matriz de Medidas y Controles Implementados

Categoría	Medida de Control	Objetivo Normativo
Gobernanza	Manual de Procedimientos para el Administrador de Unidad	Asegurar Responsabilidad Proactiva (Accountability).
Privacidad	Tokenización de saldos y Score DICOM	Protección del Secreto Bancario (Art. 154 LGB).
Ciberseguridad	Segmentación Lógica (Firewalls Capa 7)	Blindaje de Infraestructura Crítica (Ley 21.663).

Categoría	Medida de Control	Objetivo Normativo
Jurídico	Anexo de Responsabilidad Penal y Reserva	Mitigación de brechas por "insider threat".

3. Proyección de Mejora y Métricas de Cumplimiento (KPIs)

Para garantizar la resiliencia del modelo OIV, se establece un monitoreo de 180 días basado en:

- **Nivel de Adopción (NA):** % de accesos al Core Bancario validados mediante MFA (Meta: 100%).
- **Integridad del Activo (IA):** Número de intentos de movimiento lateral desde Retail detectados (Meta: 0).
- **Cumplimiento Normativo (CN):** Tiempo de reporte a la ANCI ante incidentes (Meta: < 180 min).

4. Estrategia de Certificación ante la APDP

Se procederá a la validación del **Modelo de Prevención de Infracciones** de OmniBank. Este hito es crítico para actuar como atenuante de responsabilidad ante la futura Agencia de Protección de Datos, considerando que el sector financiero enfrenta las multas más elevadas del sistema (hasta 20.000 UTM).

5. Resiliencia Técnica e Infraestructura Crítica (OIV)

En cumplimiento con la Ley 21.663, se ha ratificado:

- **Cifrado AES-256:** Aplicado a todo el dataset `omnibank_clientes.csv`.
- **Zero Trust:** Implementación de privilegios mínimos para el personal de TI del Holding.
- **Backup Inmutable:** Garantía de disponibilidad ante ataques de Ransomware dirigidos a la ICI.

6. Conclusión Final y Dictamen de Auditoría

La auditoría en **OmniBank** concluye con un dictamen de **CUMPLIMIENTO VERIFICADO BAJO ESTÁNDAR OIV**. Se ha eliminado la interconexión ilícita de datos con el Retail y se ha establecido una capa de gobernanza bajo ISO 27701 que garantiza la transparencia y la seguridad nacional financiera.